

LAPORAN PRAKTIKUM 11
MATA KULIAH DEVELOPMENT OPERATION
“Analisis Keamanan Sederhana dengan SonarQube Berbasis Docker”



Dosen Pengampu : Hastari Utama, M.Cs

Disusun Oleh:

Nama : Muhammad Rizki Fajri

NIM : 23.01.5094

Kelas : D3-TI-03

PROGRAM STUDI D3 TEKNIK INFORMATIKA
FAKULTAS ILMU KOMPUTER
UNIVERSITAS AMIKOM YOGYAKARTA

2025

A. Dasar Teori

1) Apa itu Static Application Security Testing (SAST)?

SAST adalah metode pengujian keamanan yang menganalisis source code atau bytecode sebuah aplikasi untuk menemukan celah keamanan. Proses ini dilakukan tanpa menjalankan aplikasi (statis). SAST sangat efektif untuk menemukan kerentanan seperti SQL Injection, Cross-Site Scripting (XSS), dan konfigurasi yang tidak aman langsung dari kode sumbernya.

2) Apa itu SonarQube?

SonarQube adalah platform open-source terkemuka untuk inspeksi kualitas dan keamanan kode secara berkelanjutan. Ia tidak hanya mencari kerentanan keamanan (vulnerabilities), tetapi juga bugs (kesalahan logika) dan code smells (kode yang tidak efisien/sulit dipelihara). SonarQube menjadi alat sentral dalam praktik DevSecOps untuk memastikan kode yang ditulis bersih, efisien, dan aman.

3) Mengapa Menggunakan Docker?

Docker adalah platform kontainerisasi yang memungkinkan kita untuk membungkus aplikasi beserta seluruh dependensinya dalam sebuah wadah (container) yang terisolasi. Untuk pelatihan ini, Docker memberikan keuntungan:

- a) Instalasi Cepat: Cukup satu perintah untuk menjalankan SonarQube.
- b) Lingkungan Konsisten: Lingkungan analisis sama untuk semua peserta, menghindari masalah "berhasil di komputer saya".
- c) Bersih: Mudah untuk memulai, menghentikan, dan menghapus instance SonarQube tanpa meninggalkan "sampah" di sistem operasi.

4) Apa itu SonarScanner?

SonarScanner adalah alat baris perintah (command-line interface / CLI) yang bertugas memindai kode proyek Anda, mengumpulkan data analisis, dan mengirimkannya ke server SonarQube untuk diproses dan ditampilkan di dasbor.

B. Tujuan

- 1) Menjelaskan konsep dasar SAST dan peran SonarQube dalam siklus hidup pengembangan.
- 2) Menjalankan dan mengelola server SonarQube menggunakan Docker.
- 3) Mengonfigurasi sebuah proyek aplikasi sederhana untuk dianalisis.
- 4) Menjalankan analisis kode menggunakan SonarScanner dari dalam container Docker.
- 5) Membaca dan menginterpretasikan laporan keamanan dasar pada dasbor SonarQube.
- 6) Mengidentifikasi dan memahami contoh kerentanan umum seperti kredensial yang ditulis langsung di kode (hard-coded credentials).
- 7) Menerapkan perbaikan sederhana pada kode dan memverifikasi hasilnya dengan analisis ulang.

C. Langkah langkah Praktikum

- **Langkah 1 Menyiapkan Proyek Latihan**

1. Buatlah direktori *gemini-codelab-sonar-py*.

```
D:\DevOps\Laprak11>mkdir gemini-codelab-sonar-py
```

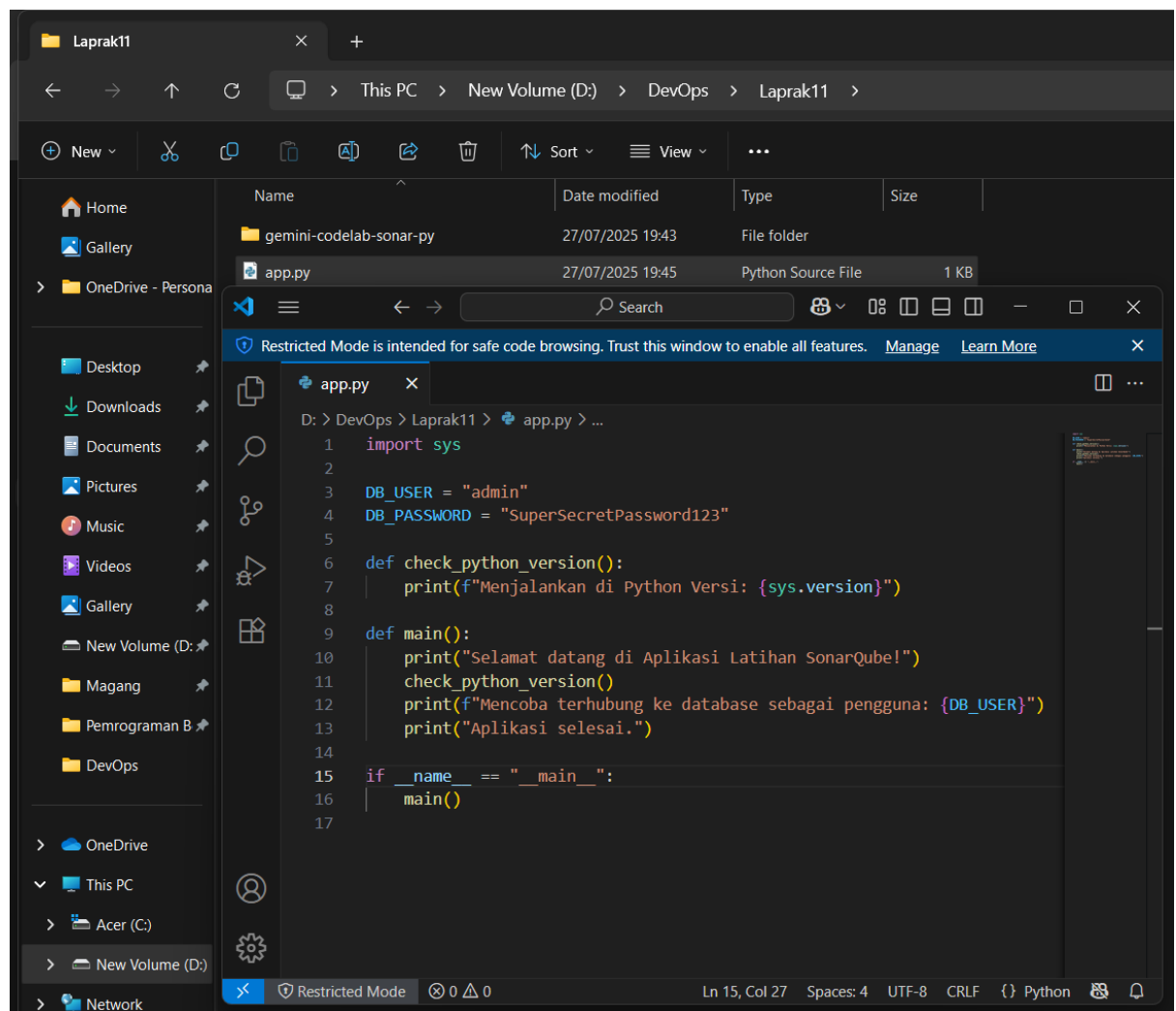
2. Masuk ke direktori tersebut dengan mengetikkan perintah:

```
cd gemini-codelab-sonar-py
```

```
D:\DevOps\Laprak11>cd gemini-codelab-sonar-py
```

```
D:\DevOps\Laprak11\gemini-codelab-sonar-py>|
```

3. Lihat isi file *app.py*. Anda akan menemukan ada *password* yang ditulis langsung di dalam kode. Ini adalah kerentanan yang akan kita deteksi.



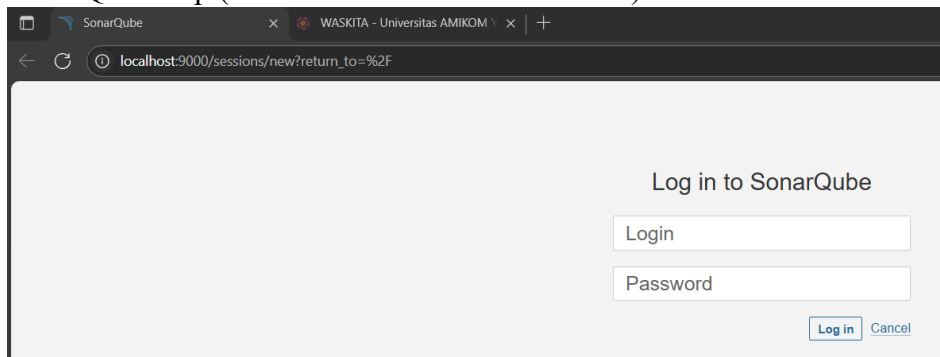
- **Langkah 2 Menjalankan Sonarqube Server dengan Docker**

1. Di terminal, jalankan perintah berikut untuk mengunduh dan menjalankan SonarQube Community Edition:

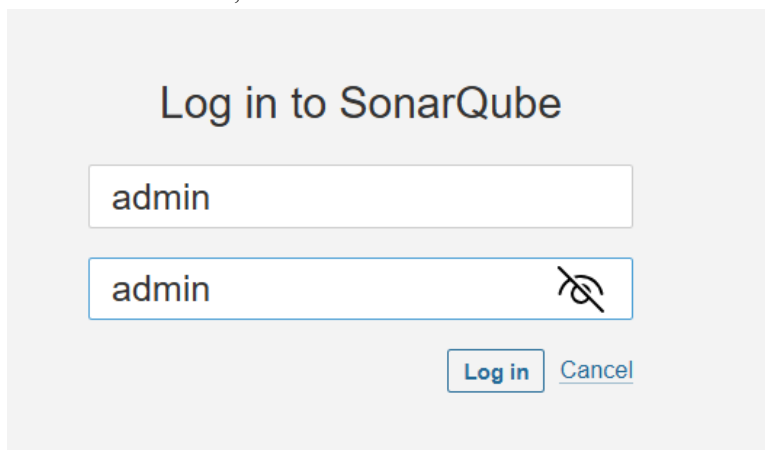
`docker run -d --name sonarqube -p 9000:9000 -p 9092:9092 sonarqube:lts-community`

```
PS D:\DevOps\Laprak11> docker run -d --name sonarqube -p 9000:9000 -p 9092:9092 sonarqube:lts-community
Unable to find image 'sonarqube:lts-community' locally
lts-community: Pulling from library/sonarqube
4f4fb700ef54: Already exists
1824101659b5: Download complete
b0d063b69b5d: Download complete
1791a8ed1ca8: Pulling fs layer
b8f81c124c7b: Pulling fs layer
```

2. Buka browser dan akses **http://localhost:9000**. Tunggu beberapa saat hingga SonarQube siap (bisa memakan waktu 1-3 menit).



3. Login dengan kredensial default:
Username: admin, Password: admin



4. Anda akan diminta untuk segera mengubah password. Lakukan dan simpan password baru Anda di tempat yang aman.

Update your password

This account should not use the default password.

Enter a new password

All fields marked with * are required

Old Password *

New Password *

Confirm Password *

[Update](#)

sonarqube

ProjectsIssuesRulesQuality ProfilesQuality GatesAdministration

Search for projects...

A

How do you want to create your project?

Do you want to benefit from all of SonarQube's features (like repository import and Pull Request decoration)? Create your project from your favorite DevOps platform. First, you need to set up a DevOps platform configuration.



From Azure DevOps

Set up global configuration



From Bitbucket Server

Set up global configuration



From Bitbucket Cloud

Set up global configuration



From GitHub

Set up global configuration



From GitLab

Set up global configuration

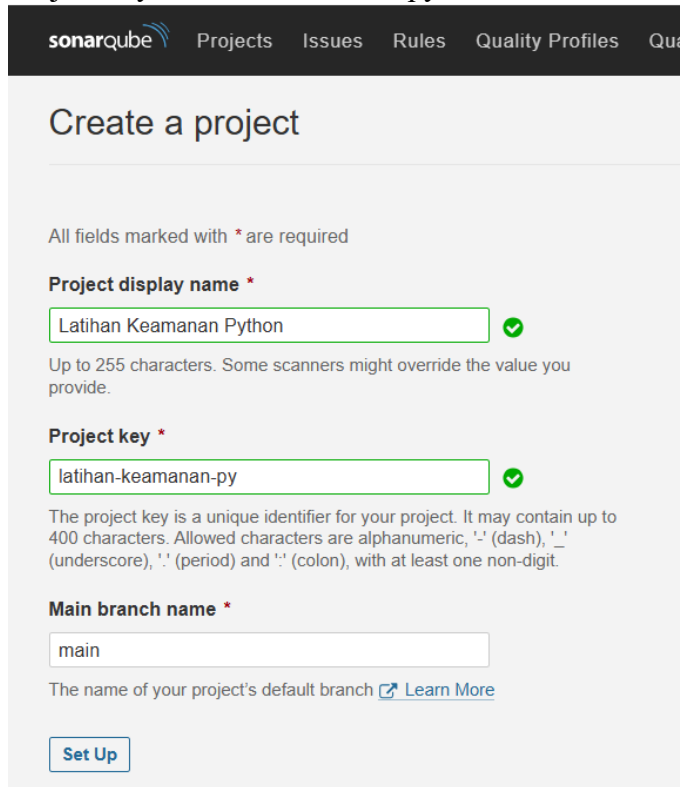
Are you just testing or have an advanced use-case? Create a project manually.



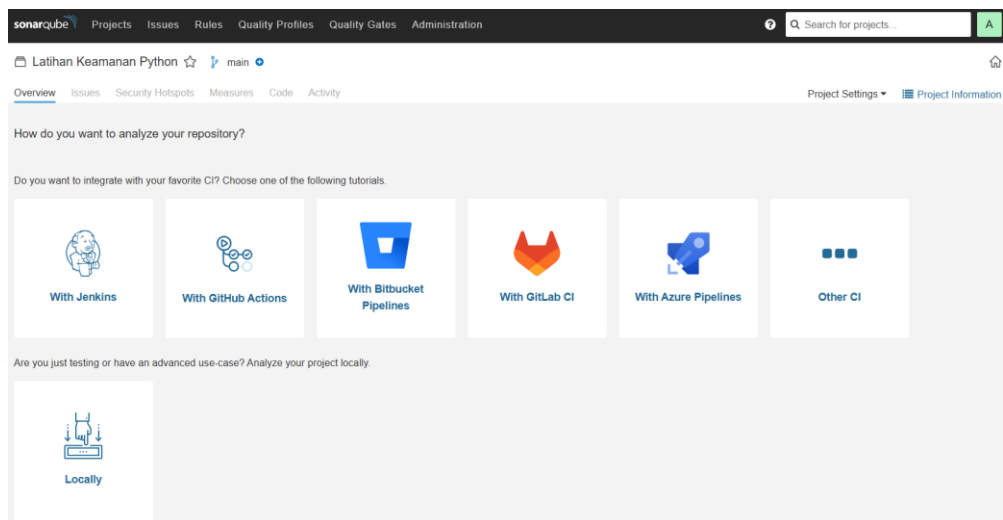
Manually

- **Langkah 3: Membuat Proyek dan Token di SonarQube**

1. Setelah login, klik "Create new project".
2. Pilih "Manually".
3. Isi formulir:
 - Project display name: Latihan Keamanan Python
 - Project key: latihan-keamanan-py



The screenshot shows the 'Create a project' form in SonarQube. The form has a dark header with the SonarQube logo and navigation links: Projects, Issues, Rules, Quality Profiles, and Quality Gates. The main title is 'Create a project'. Below the title, a note states 'All fields marked with * are required'. The form contains three input fields: 'Project display name *' with the value 'Latihan Keamanan Python', 'Project key *' with the value 'latihan-keamanan-py', and 'Main branch name *' with the value 'main'. Each field has a green checkmark icon to its right. Below the 'Project key' field, there is a detailed explanation: 'The project key is a unique identifier for your project. It may contain up to 400 characters. Allowed characters are alphanumeric, '-' (dash), '_' (underscore), '.' (period) and ':' (colon), with at least one non-digit.' At the bottom of the form is a 'Set Up' button.



4. Klik "Set Up". Pada halaman berikutnya, di bawah "Provide a token", pilih "Generate a token".
5. Beri nama token Anda (misal: scanner-token) dan klik "Generate".

Latihan Keamanan Python ☆ 🔒 main

Overview Issues Security Hotspots Measures Code Activity

Analyze your project

We initialized your project on SonarQube, now it's up to you to launch analyses!

1 Provide a token

Generate a project token

Token name ⓘ

Expires in

scanner-token

30 days ▾

Generate

ⓘ

Please note that this token will only allow you to analyze the current project. If you want to use the same token to analyze multiple projects, you need to generate a global token in your [user account](#). See the [documentation](#) for more information.

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your [user account](#).

6. Salin (copy) token yang muncul. Token ini hanya muncul sekali, jadi simpan baik - baik.

1 Provide a token

scanner-token: **sqp_fcd5ffc87bcf935eb3eb041923bdf23e8bc5797b** 🗑️

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your [user account](#).

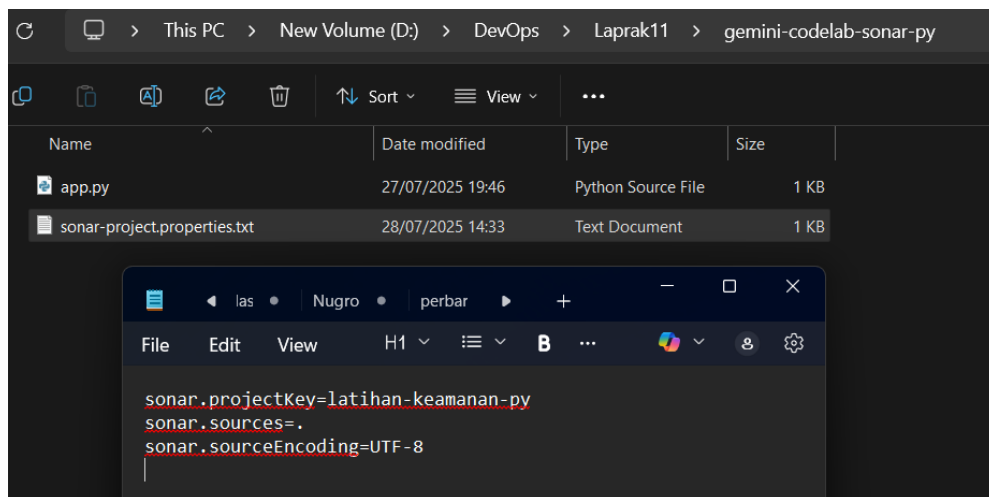
Continue

sqp_fcd5ffc87bcf935eb3eb041923bdf23e8bc5797b

- **Langkah 4: Menjalankan Analisis dengan SonarScanner (via Docker)**

1. Pastikan Anda masih berada di direktori proyek (gemini-codelab-sonar-py) di terminal.

gemini-codelab-sonar-py 27/07/2025 19:43 File folder



2. Jalankan SonarScanner menggunakan Docker. Ganti <TOKEN_ANDA> dengan token yang baru

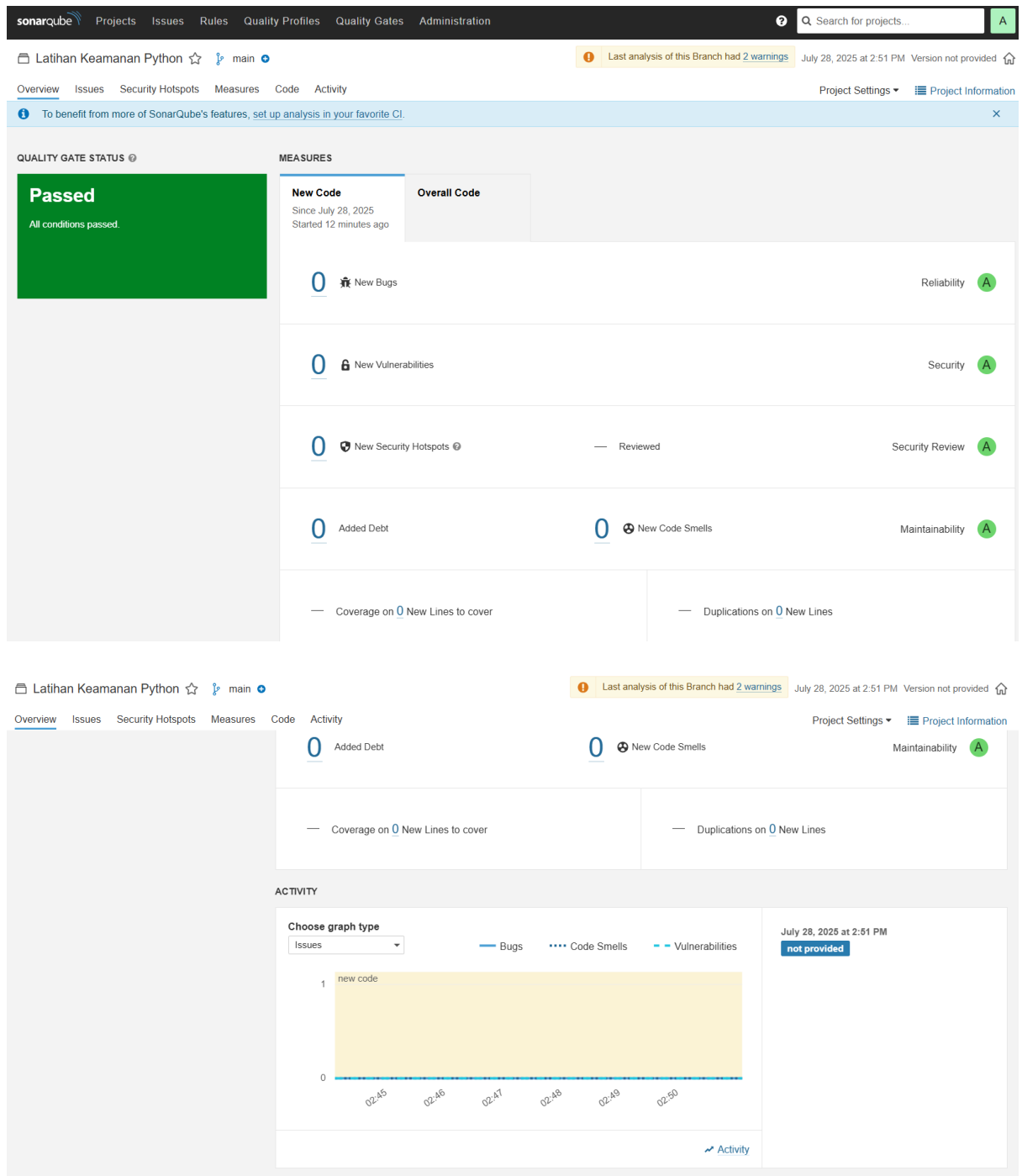
Langkah 1: Buat File Konfigurasi Baru

```
PS D:\DevOps\Laprak11\gemini-codelab-sonar-py> docker run --rm -it --network="host" -e SONAR_HOST_URL="http://localhost:9000" -e SONAR_TOKEN="sq_p_fcd5ffcc87bcf935eb041923bdf23e8bc5797b" -v "${PWD}:/usr/src" sonarsource/sonar-scanner-cli "-Dsonar.projectKey=latihan-keamanan-py" "-Dsonar.sources=."
```

```
07:51:25.287 INFO Scanner configuration file: /opt/sonar-scanner/conf/sonar-scanner.properties
07:51:25.295 INFO Project root configuration file: /usr/src/sonar-project.properties
07:51:25.337 INFO SonarScanner CLI 7.2.0.5079
07:51:25.342 INFO Linux 5.15.167.4-microsoft-standard-WSL2 amd64
07:51:27.312 INFO Communicating with SonarQube Server 9.9.8.100196
07:51:29.188 INFO Load global settings
07:51:29.345 INFO Load global settings (done) | time=159ms
07:51:29.349 INFO Server id: 147B411E-AZhP0NeIpGRZIatQp_jH
07:51:29.364 INFO User cache: /opt/sonar-scanner/.sonar/cache
07:51:29.369 INFO Load/download plugins
07:51:29.369 INFO Load plugins index
07:51:29.462 INFO Load plugins index (done) | time=93ms
07:51:34.024 INFO Load/download plugins (done) | time=4655ms
07:51:34.938 INFO Process project properties
07:51:34.963 INFO Process project properties (done) | time=25ms
07:51:34.968 INFO Execute project builders
07:51:34.976 INFO Execute project builders (done) | time=8ms
07:51:34.999 INFO Project key: latihan-keamanan-py
07:51:34.999 INFO Base dir: /usr/src

07:51:43.707 INFO Sensor IaC Docker Sensor [iac]
07:51:43.711 INFO 0 source files to be analyzed
07:51:43.797 INFO 0/0 source files have been analyzed
07:51:43.797 INFO Sensor IaC Docker Sensor [iac] (done) | time=90ms
07:51:43.808 INFO ----- Run sensors on project
07:51:43.912 INFO Sensor Analysis Warnings import [csharp]
07:51:43.917 INFO Sensor Analysis Warnings import [csharp] (done) | time=5ms
07:51:43.919 INFO Sensor Zero Coverage Sensor
07:51:43.937 INFO Sensor Zero Coverage Sensor (done) | time=18ms
07:51:43.941 INFO SCM Publisher No SCM system was detected. You can use the 'sonar.scm.provider' property to explicitly specify it.
07:51:43.946 INFO CPD Executor Calculating CPD for 1 file
07:51:43.973 INFO CPD Executor CPD calculation finished (done) | time=27ms
07:51:44.089 INFO Analysis report generated in 107ms, dir size=124.0 kB
07:51:44.115 INFO Analysis report compressed in 26ms, zip size=17.5 kB
07:51:44.206 INFO Analysis report uploaded in 90ms
07:51:44.212 INFO ANALYSIS SUCCESSFUL, you can find the results at: http://localhost:9000/dashboard?id=latihan-keamanan-py
07:51:44.213 INFO Note that you will be able to access the updated dashboard once the server has processed the submitted analysis report
07:51:44.213 INFO More about the report processing at http://localhost:9000/api/ce/task?id=AZhQB8dpGRZIatQqJcj
07:51:44.249 INFO Analysis total time: 9.969 s
07:51:44.252 INFO EXECUTION SUCCESS
07:51:44.253 INFO Total time: 18.974s
```

3. Buka direktori proyek Anda (gemini-codelab-sonar-py) di file explorer atau editor kode.
4. Di dalam direktori tersebut (di lokasi yang sama dengan file app.py), buat sebuah file baru dengan nama **sonar-project.properties**.



- **Langkah 5: Isi File Konfigurasi**
 1. Membuat file konfigurasi langsung di dalam proyek Anda, di dalam folder **gemini codelab-sonar-py**. Salin dan tempel (copy-paste) teks di bawah ini ke dalam file **sonar-project.properties** yang baru saja Anda buat
 2. **Menjalankan Sonar Scanner CLi Untuk Pengguna Windows (CMD/PowerShell):**

```

PS D:\DevOps\Laprak11\gemini-codelab-sonar-py> docker run --rm -it --network="host" -e SONAR_HOST_URL="http://localhost:9000" -e SONAR_TOKEN="sq
p_fcd5ffc87bcf935eb3eb041923bdf23e8bc5797b" -v "${PWD}:/usr/src" sonarsource/sonar-scanner-cli "-Dsonar.projectKey=latihan-keamanan-py" "-Dsonar
.sources=/"
07:51:25.287 INFO Scanner configuration file: /opt/sonar-scanner/conf/sonar-scanner.properties
07:51:25.295 INFO Project root configuration file: /usr/src/sonar-project.properties
07:51:25.337 INFO SonarScanner CLI 7.2.0.5079
07:51:25.342 INFO Linux 5.15.167.4-microsoft-standard-WSL2 amd64
07:51:27.312 INFO Communicating with SonarQube Server 9.9.8.100196
07:51:29.188 INFO Load global settings
07:51:29.345 INFO Load global settings (done) | time=159ms
07:51:29.349 INFO Server id: 147B411E-AZhP0NeIpGRZIatQp_jH
07:51:29.364 INFO User cache: /opt/sonar-scanner/.sonar/cache
07:51:29.369 INFO Load/download plugins
07:51:29.369 INFO Load plugins index
07:51:29.462 INFO Load plugins index (done) | time=93ms
07:51:34.024 INFO Load/download plugins (done) | time=4655ms
07:51:34.938 INFO Process project properties
07:51:34.963 INFO Process project properties (done) | time=25ms
07:51:34.968 INFO Execute project builders
07:51:34.976 INFO Execute project builders (done) | time=8ms
07:51:34.999 INFO Project key: latihan-keamanan-py
07:51:34.999 INFO Base dir: /usr/src

```

3. Biarkan proses analisis berjalan hingga Anda melihat pesan **EXECUTION SUCCESS**.

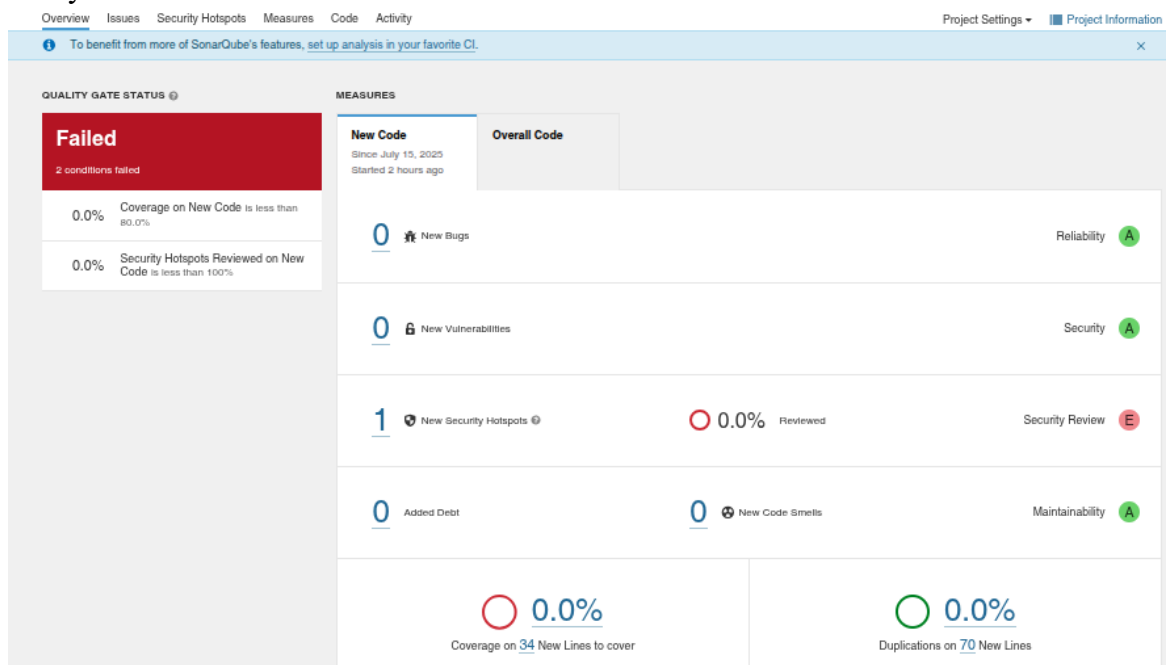
```

07:51:44.252 INFO EXECUTION SUCCESS
07:51:44.253 INFO Total time: 18.974s

```

• Langkah 6: Melihat Hasil Analisis

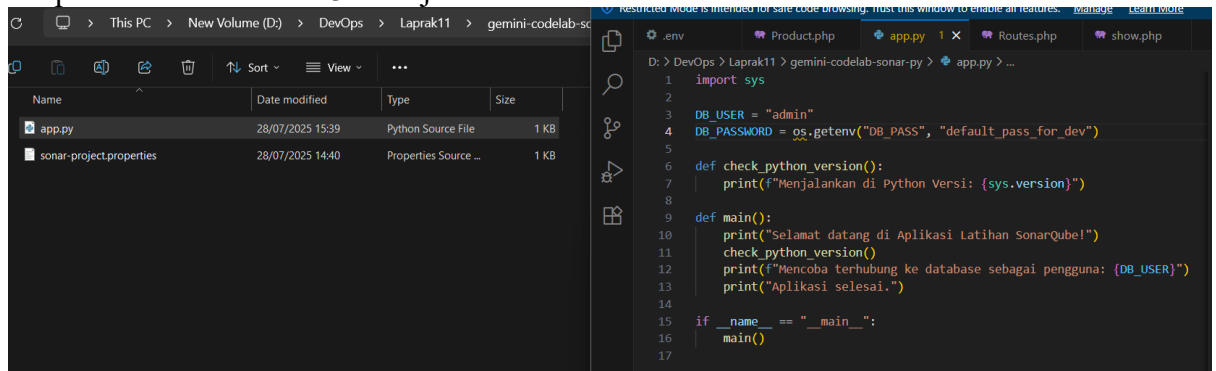
1. Kembali ke browser Anda di halaman proyek SonarQube (<http://localhost:9000>).
2. Refresh halaman. Anda akan melihat dasbor analisis telah terisi.
3. Perhatikan bagian "**Security Hotspots**" atau "**Bugs**". SonarQube akan menandai adanya masalah.



D. Studi Kasus dan Penyelesaian

- **Perbaiki Kode**

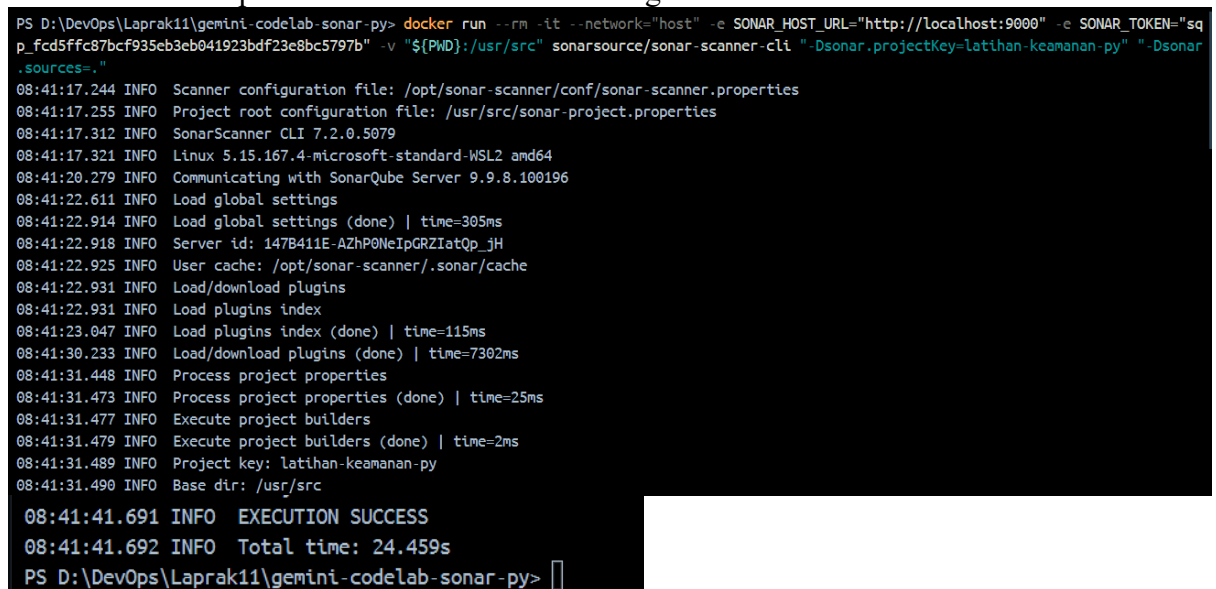
1. Buka dan ubah file app.py. Ganti baris DB_PASSWORD = "SuperSecretPassword123" menjadi



```
1 import sys
2
3 DB_USER = "admin"
4 DB_PASSWORD = os.getenv("DB_PASS", "default_pass_for_dev")
5
6 def check_python_version():
7     print(f"Menjalankan di Python Versi: {sys.version}")
8
9
10 def main():
11     print("Selamat datang di Aplikasi Latihan SonarQube!")
12     check_python_version()
13     print(f"Mencoba terhubung ke database sebagai pengguna: {DB_USER}")
14     print("Aplikasi selesai.")
15
16 if __name__ == "__main__":
17     main()
```

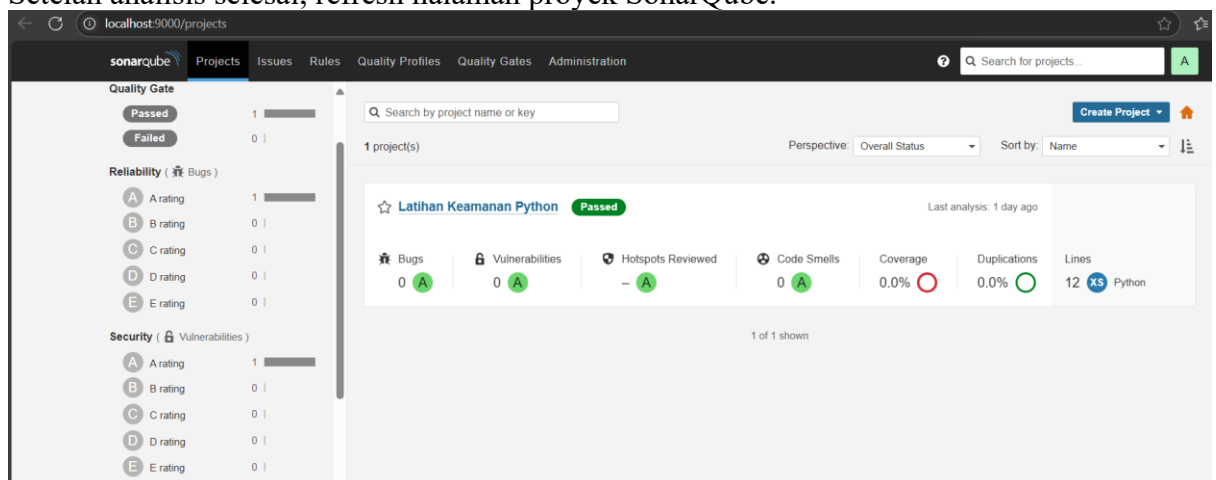
- **Verifikasi Perbaikan**

- a) Jalankan kembali perintah SonarScanner dari Langkah 4

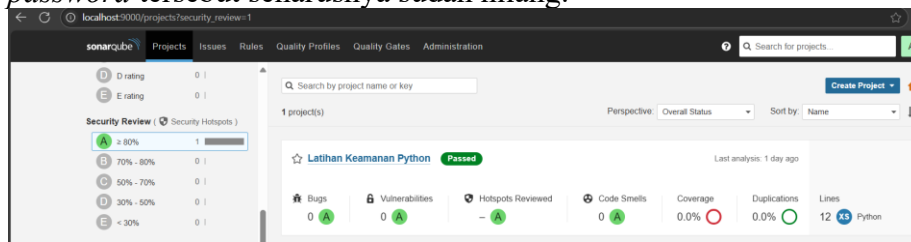


```
PS D:\DevOps\Laprak11\gemini-codelab-sonar-py> docker run --rm -it --network="host" -e SONAR_HOST_URL="http://localhost:9000" -e SONAR_TOKEN="sq_p_fcd5ffc87bcf935eb3eb041923bdf23e8bc5797b" -v "${PWD}:/usr/src" sonarsource/sonar-scanner-cli "-Dsonar.projectKey=latihan-keamanan-py" "-Dsonar.sources=."
08:41:17.244 INFO Scanner configuration file: /opt/sonar-scanner/conf/sonar-scanner.properties
08:41:17.255 INFO Project root configuration file: /usr/src/sonar-project.properties
08:41:17.312 INFO SonarScanner CLI 7.2.0.5079
08:41:17.321 INFO Linux 5.15.167.4-microsoft-standard-WSL2 amd64
08:41:20.279 INFO Communicating with SonarQube Server 9.9.8.100196
08:41:22.611 INFO Load global settings
08:41:22.914 INFO Load global settings (done) | time=305ms
08:41:22.918 INFO Server id: 147B411E-AZhP0NeIpGRZiAtOp_jH
08:41:22.925 INFO User cache: /opt/sonar-scanner/.sonar/cache
08:41:22.931 INFO Load/download plugins
08:41:22.931 INFO Load plugins index
08:41:23.047 INFO Load plugins index (done) | time=115ms
08:41:30.233 INFO Load/download plugins (done) | time=7302ms
08:41:31.448 INFO Process project properties
08:41:31.473 INFO Process project properties (done) | time=25ms
08:41:31.477 INFO Execute project builders
08:41:31.479 INFO Execute project builders (done) | time=2ms
08:41:31.489 INFO Project key: latihan-keamanan-py
08:41:31.490 INFO Base dir: /usr/src
08:41:41.691 INFO EXECUTION SUCCESS
08:41:41.692 INFO Total time: 24.459s
PS D:\DevOps\Laprak11\gemini-codelab-sonar-py>
```

- b) Setelah analisis selesai, refresh halaman proyek SonarQube.



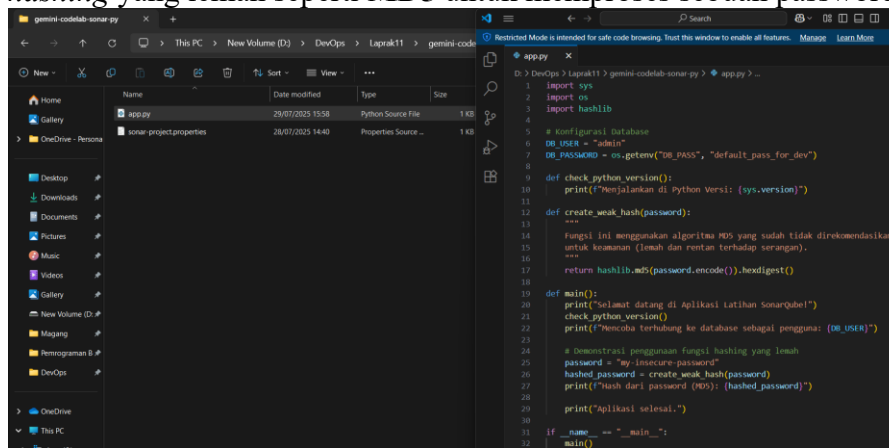
- c) Lihat pada tab **"Security Hotspots"**. Kerentanan terkait *hard-coded password* tersebut seharusnya sudah hilang.



E. Tugas

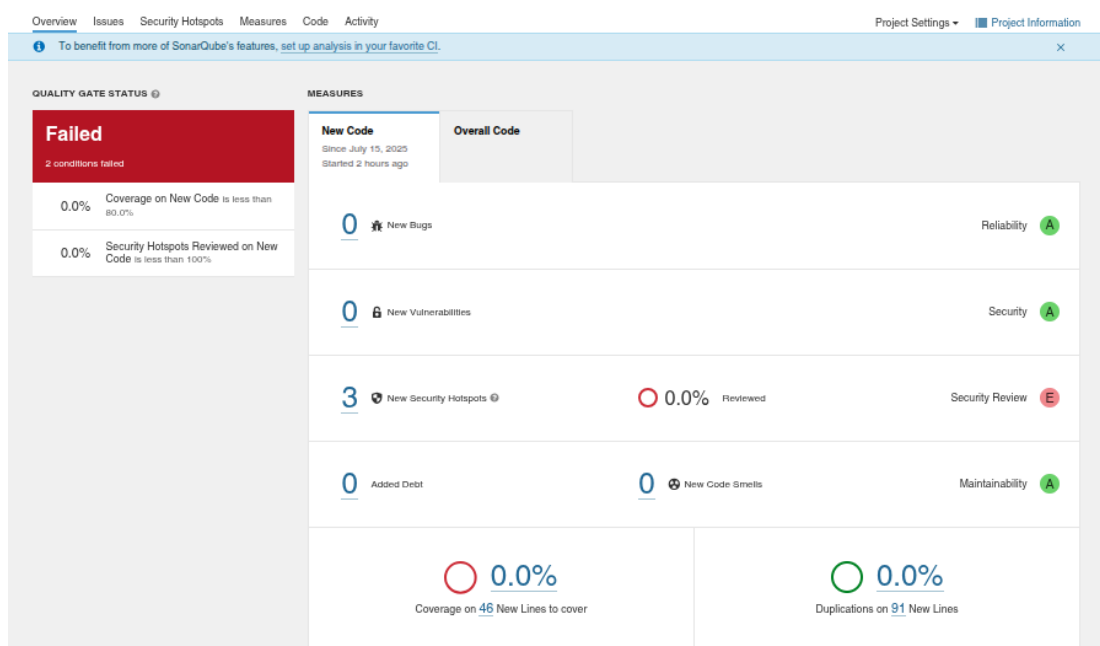
1. Menambahkan Kerentanan Baru:

Edit file `app.py` dan tambahkan sebuah fungsi baru yang menggunakan algoritma *hashing* yang lemah seperti **MD5** untuk memproses sebuah password. Contoh:



2. Analisis Hasil:

Periksa dasbor SonarQube. Apakah SonarQube berhasil mendeteksi penggunaan algoritma kriptografi yang lemah tersebut? (Biasanya akan muncul sebagai *Security Hotspot* atau *Vulnerability*). Buat tangkapan layer (*screenshot*) dari temuan tersebut di SonarQube.



Filters

Assigned to me **All**

Status

To review ▾

Overall code ▾

Security Hotspots Reviewed 0 —



There are no Security Hotspots to review.

Next time you analyze a piece of code that contains a potential security risk, it will show up here.

[🔗 Learn more about Security Hotspots](#)